

Vulnerability Scanning Overview

As discussed earlier, vulnerability scanning is performed to identify potential vulnerabilities in network devices such as routers, firewalls, switches, as well as servers, workstations, and applications. Scanning is automated and focuses on finding potential/known vulnerabilities on the network or at the application level. **Vulnerabilities scanners typically do not exploit vulnerabilities (with some exceptions) but need a human to manually validate scan issues** to determine whether or not a particular scan returned real issues that need to be fixed or false positives that can be ignored and excluded from future scans against the same target.

Vulnerability scanning is often part of a standard penetration test, but the two are not the same. A vulnerability scan can help gain additional coverage during a penetration test or speed up the project's testing under time constraints. An actual penetration test includes much more than just a scan.

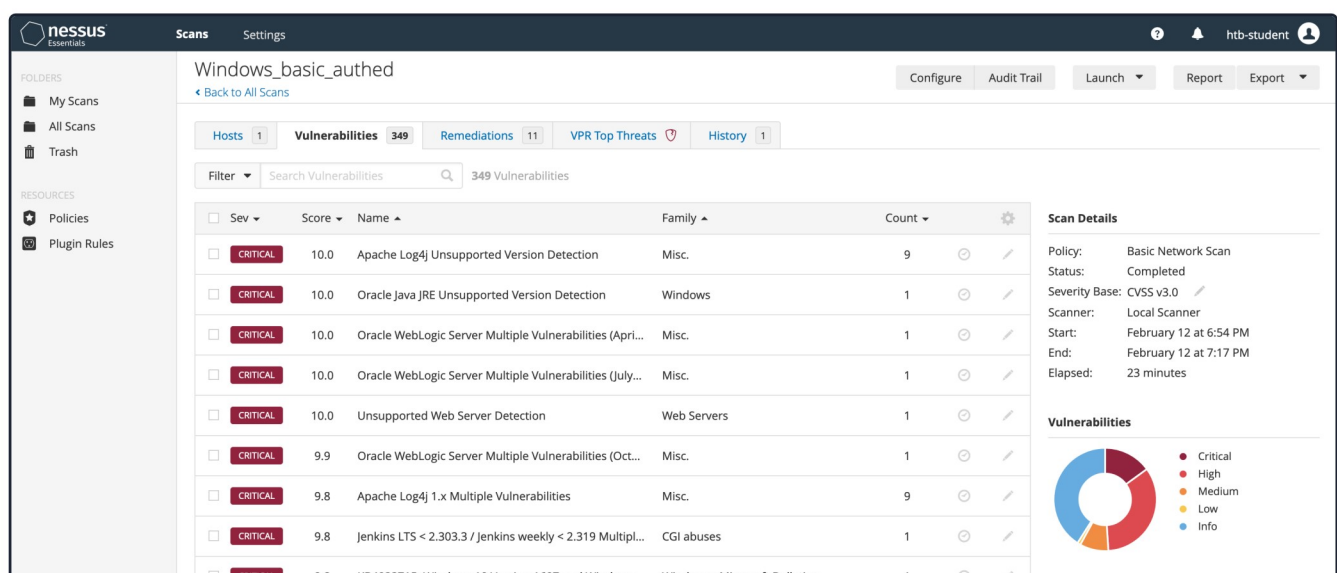
The type of scans run varies from one tool to another, but most tools **run a combination of dynamic and static tests**, depending on the target and the vulnerability. A **static test** would determine a vulnerability if the identified version of a particular asset has a public CVE. However, this is not always accurate as a patch may have been applied, or the target isn't specifically vulnerable to that CVE. On the other hand, a **dynamic test** tries specific (usually benign) payloads such as weak credentials, SQL injection, or command injection on the target (i.e., a web application). If any payload returns a hit, then there's a good chance that it is vulnerable.

Organizations should run both **unauthenticated and authenticated scans** on a continuous schedule to ensure that assets are patched as new vulnerabilities are discovered and that any new assets added to the network do not have missing patches or other configuration/patching issues. Vulnerability scanning should feed into an organization's **patch management** program.

Nessus, **Nexpose**, and **Qualys** are well-known vulnerability scanning platforms that also provide free community editions. There are also open-source alternatives such as **OpenVAS**.

Nessus Overview

Nessus Essentials by Tenable is the free version of the official Nessus Vulnerability Scanner. Individuals can access Nessus Essentials to get started understanding Tenable's vulnerability scanner. The caveat is that it can only be used for up to 16 hosts. The features in the free version are limited but are perfect for someone looking to get started with Nessus. The free scanner will attempt to identify vulnerabilities in an environment.



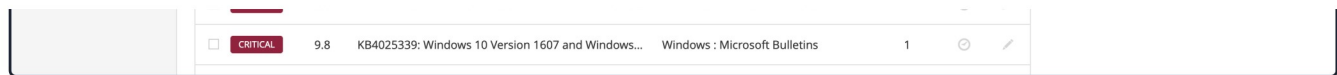
Sev	Score	Name	Family	Count
CRITICAL	10.0	Apache Log4j Unsupported Version Detection	Misc.	9
CRITICAL	10.0	Oracle Java JRE Unsupported Version Detection	Windows	1
CRITICAL	10.0	Oracle WebLogic Server Multiple Vulnerabilities (Apri...	Misc.	1
CRITICAL	10.0	Oracle WebLogic Server Multiple Vulnerabilities (July...	Misc.	1
CRITICAL	10.0	Unsupported Web Server Detection	Web Servers	1
CRITICAL	9.9	Oracle WebLogic Server Multiple Vulnerabilities (Oct...	Misc.	1
CRITICAL	9.8	Apache Log4j 1.x Multiple Vulnerabilities	Misc.	9
CRITICAL	9.8	Jenkins LTS < 2.303.3 / Jenkins weekly < 2.319 Multipl...	CGI abuses	1
CRITICAL	9.8	KB4022715: Windows 10 Version 1607 and Windows...	Windows : Microsoft Bulletins	1

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: February 12 at 6:54 PM
End: February 12 at 7:17 PM
Elapsed: 23 minutes

Vulnerabilities

Donut chart showing severity distribution: Critical (red), High (orange), Medium (yellow), Low (green), Info (blue).



OpenVAS Overview

[OpenVAS](#) by Greenbone Networks is a publicly available open-source vulnerability scanner. OpenVAS can perform network scans, including authenticated and unauthenticated testing.

[← Previous](#)[Next →](#)[✔ Mark Complete & Next](#)

Table of Contents

Security Assessments

[Security Assessments](#)[Vulnerability Assessment](#)[Assessment Standards](#)

Vulnerability Scoring and Reporting

[Common Vulnerability Scoring System \(CVSS\)](#)[Common Vulnerabilities and Exposures \(CVE\)](#)

Nessus

[Vulnerability Scanning Overview](#)

Getting Started with Nessus

Nessus Scan

Advanced Settings

Working with Nessus Scan Output

Scanning Issues

 Nessus Skills Assessment

OpenVAS

Getting Started with OpenVAS

OpenVAS Scan

Exporting The Results

 OpenVAS Skills Assessment

Reporting

Reporting

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left